

123 - Account logout

Заклучването на акаунт се прави със защитна цел, за да се намали вероятността от brute-force атаки.

ASP.NET Core Account Lockout



Политиката за ограничаване включва например до 5 неправилни опита за въвеждане на парола, след което 15 минути забрана за достъп, след което още право на 5 опита и ако те са грешни, може би още 15 минути блок. Това би забавило една брут-форс атака с години. Това може да се комбинира с други ограничения като 1 месец да нямаш право да сменяш парола и т.н.

Configure Account Lockout Options

```
public void ConfigureServices(IServiceCollection services)
{
    services.AddIdentity<ApplicationUser, IdentityRole>(options =>
    {
        options.Lockout.MaxFailedAccessAttempts = 5;
        options.Lockout.DefaultLockoutTimeSpan = TimeSpan.FromMinutes(15);
    });

    // Rest of the code
}
```

```
EmployeeManagement.Startup | ConfigureServices(IServiceCollection services)
services.AddDbContextPool<AppDbContext>(
    options => options.UseSqlServer(_config.GetConnectionString("EmployeeDBCon

services.AddIdentity<ApplicationUser, IdentityRole>(options =>
{
    options.Password.RequiredLength = 10;
    options.Password.RequiredUniqueChars = 3;

    options.SignIn.RequireConfirmedEmail = true;
    options.Tokens.EmailConfirmationTokenProvider = "CustomEmailConfirmation";

    options.Lockout.MaxFailedAccessAttempts = 5;
    options.Lockout.DefaultLockoutTimeSpan = TimeSpan.FromMinutes(15);
});
}).AddEntityFrameworkStores<AppDbContext>()
```

```
options.Lockout.MaxFailedAccessAttempts = 5;
```

```
options.Lockout.DefaultLockoutTimeSpan = TimeSpan.FromMinutes(15);
```

Enable Account Lockout in ASP.NET Core

```
public class SignInManager<TUser> where TUser : class
{
    public virtual Task<SignInResult> PasswordSignInAsync(string userName, string
        password, bool isPersistent, bool lockoutOnFailure)
    }
}
```

Pass **true** to enable account lockout

За да имаме тази функционалност, всичко, което трябва да направим, е резултат True за bool lockOnFailure. Това се изпълнява от SignInManager service в Account controller, Login action, Post:

```
AccountController.cs AddPasswordConfirmation.cshtml AddPasswordViewModel.cs
EmployeeManagement.Controllers.AccountController Login(LoginViewModel model, string returnUrl)
var result = await signInManager.PasswordSignInAsync(model.Email, model.Password,
    model.RememberMe, false);
```

От IntelliSense виждаме, че последният параметър на .PasswordSignInAsync – bool lockOutFailure

```
.PasswordSignInAsync(model.Email, model.Password,
Search Sol
(awaitable) Task<Microsoft.AspNetCore.Identity.SignInResult>
SignInManager<ApplicationUser>.PasswordSignInAsync(string userName, string
password, bool isPersistent, bool lockoutOnFailure) (+ 1 overload)
Attempts to sign in the specified userName and password combination as an
asynchronous operation.
Returns:
The task object representing the asynchronous operation containing the
SignInResult for the sign-in attempt.
```

е бил зададен при нас като false, т.е. няма защитно заключване, затова го активираме с true.

```
.PasswordSignInAsync(model.Email, model.Password,
    model.RememberMe, true); Lock
```

С тази промяна, всеки грешен опит за въвеждане на парола ще се регистрира, като стойността в колоната на БД Users ще се увеличава +1 при всяка грешка.

	PhoneNumber...	TwoFactorEna...	LockoutEnd	LockoutEnabled	AccessFailedC...	City
▶	False	False	NULL	True	0	Sofia
	False	False	NULL	True	0	NULL
	False	False	NULL	True	0	London

Така че, когато стойността достигне зададената (в нашия случай за 5 грешни опита), акаунтът ще се заключи. От Intellisense също забелязваме, че стойността, която връща PasswordSignInAsync – SignInResult. Това означава, че докато трае заключването на акаунта, той няма да се отключи дори да предоставим верни данни за име и парола на потребителя.

Returns:

The task object representing the asynchronous operation containing the **SignInResult** for the sign-in attempt.

```
AccountController.cs
var result = await signInManager.PasswordSignInAsync(model.Email, model.Password,
                                                    model.RememberMe, true);
if (result.Succeeded)
{
    if(!string.IsNullOrEmpty(returnUrl)) // && URL.LocalURL(returnURL));
    {
        return LocalRedirect(returnUrl);
    }
    else
    {
        return RedirectToAction("index", "home");
    }
}
if (result.IsLockedOut)
{
    return View("AccountLocked");
}

ModelState.AddModelError(string.Empty, "Invalid Login attempt");
```

```
if (result.IsLockedOut)
{
    return View("AccountLocked");
}
```

Все още не разполагаме с този View, така че го създаваме:

Account Locked View



```

AccountLocked.cshtml  X  dbo.AspNetUsers [Data]  AddPassword.cshtml  Acc
<h3 class="text-danger">
  Your account is locked, please try again after sometime or you may
  <a asp-action="ForgotPassword" asp-controller="Account">
    reset your password by clicking here
  </a>
</h3>

```

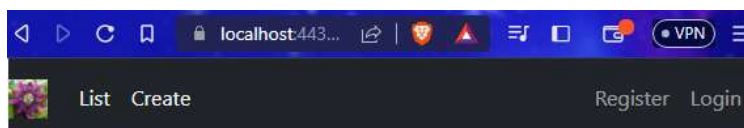
```

<h3 class="text-danger">
  Your account is locked, please try again after sometime or you may
  <a asp-action="ForgotPassword" asp-controller="Account">
    reset your password by clicking here
  </a>
</h3>

```

При 3 неуспешни опита виждаме промяната в БД, но все още нямаме заключване:

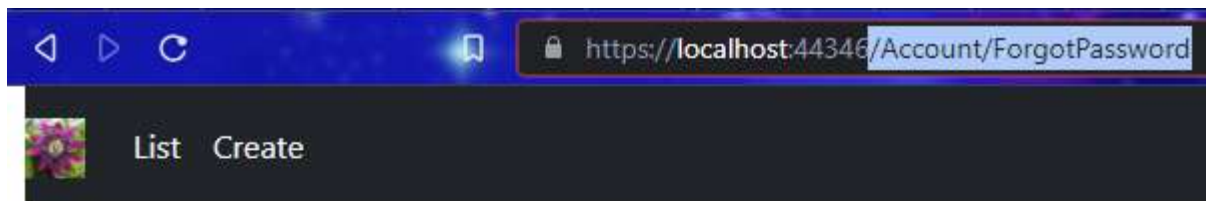
TwoFactorEna...	LockoutEnd	LockoutEnabled	AccessFailedC...	City
False	NULL	True	0	Sofia
False	NULL	True	0	NULL
False	NULL	True	0	London
False	NULL	True	0	Plovdiv
False	NULL	True	0	NULL
False	NULL	True	0	NULL
False	NULL	True	3	Sofia
False	NULL	True	0	Sofia



Your account is locked, please try again after
sometime or you may [reset your password by
clicking here](#)

Сега имаме 2 възможности: или да изчакаме 15 мин да се отключи акаунта, или да използваме линка за възстановяване на паролата, чрез който да бъде изпратена нова парола на имейла.

Ще използваме линка за възстановяване на парола, който имаме готов от урок 115



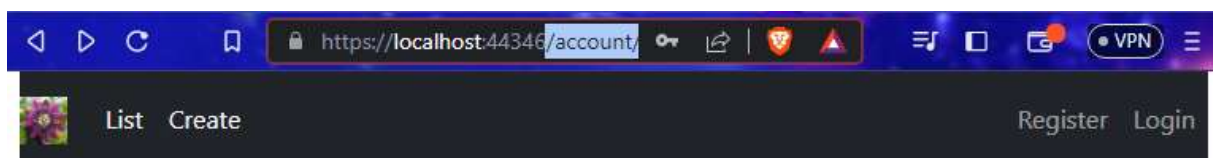
Forgot Password

Email

dima4@abv.bg

Submit

Тази функционалност е същата като от линка за регистрация:



Local Account Login

Email

Password

☐ Remember me

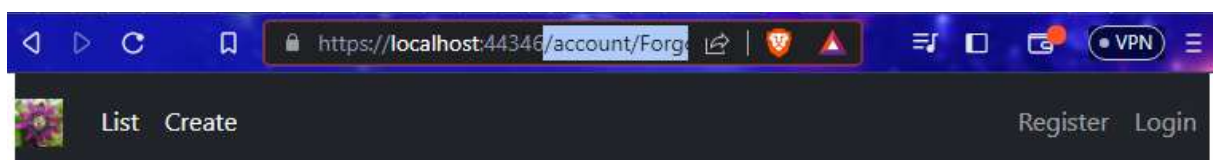
Login

[Forgot Password?](#)

External Login

Google

Facebook



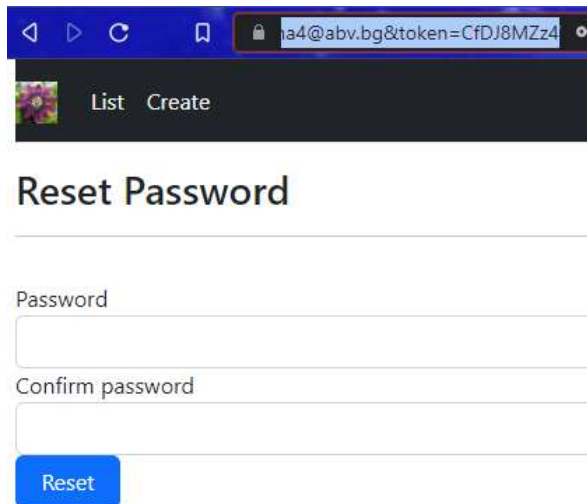
If you have an account with us, we have sent an email with the instructions to reset your password.

nlog-all-2023-03-24 - Notepad

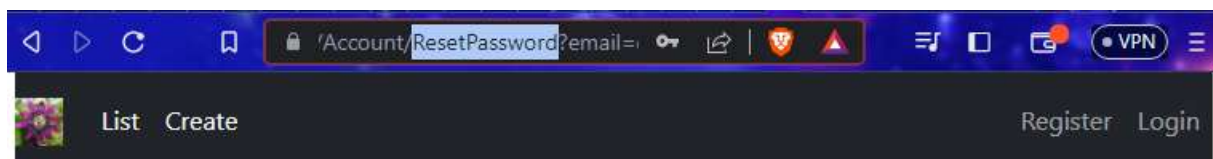
File Edit Format View Help

ps://localhost:44346/Account/ResetPassword?email=dima4@abv.bg&token=CfDJ8MZz4Vd5AbxPvxH1GIhwD:

<https://localhost:44346/Account/ResetPassword?email=dima4@abv.bg&token=CfDJ8MZz4Vd5AbxPvxH1GIhwDsoTPyD%2BQ6DvABZwbu3tbXdRLcRzDARluexAqGRCy4qUn%2B1Z5SXVABBZ8xY7n%2BGjktsUrlwTIX4cfIK2dQivU8GgAXQ%2B4SjaHJFyhIvv%2Fo5Pcnka9%2FSVvePOsxRSOP8ZpE1BKqthFw%2FcNAipbE3Q4hiaOiu8s7ClbrwgjzdvzoasZIH2fAwxencOUI%2Bka0%2FXYwhK5zm1mdu1mK%2BHaU2Zwzul>

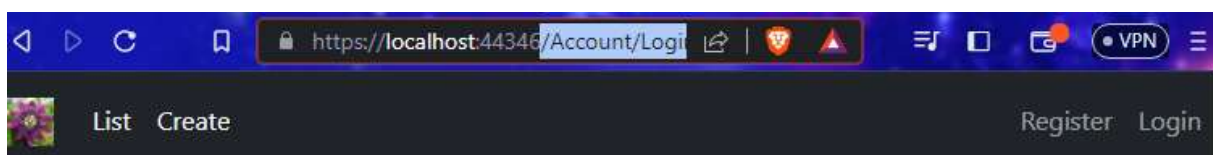


LockoutEnd	LockoutEnabled	AccessFailedC...	City
NULL	True	0	Sofia
NULL	True	0	NULL
NULL	True	0	London
NULL	True	0	Plovdiv
NULL	True	0	NULL
NULL	True	0	NULL
3/24/2023 7:57:16 AM +00:00	True	0	Sofia
NULL	True	0	Sofia



Your password is reset. Please click [here to login](#)

Когато, обаче, се впишем с новата парола, връща същата грешка, че акаунтът ни е блокиран.



Your account is locked, please try again after sometime or you may [reset your password by clicking here](#)

Един от начините да поправим това, е да въведем актуалното време в колоната за LockoutEnd.

Set Lockout End Date on Password Reset

```
var result = await userManager.ResetPasswordAsync(user, model.Token, model.Password);

if (result.Succeeded)
{
    if (await userManager.IsLockedOutAsync(user))
    {
        await userManager.SetLockoutEndDateAsync(user, DateTimeOffset.UtcNow);
    }

    return View("ResetPasswordConfirmation");
}
```

С това, достъпът със смяна на парола е възстановен.